

Artificial Intelligence Automated Cybersecurity Checking Tool.

By Jack Butlin

for this threat modelling project I am setting a target AI system, mapping possible threats and proposing mitigations for the possible threats.

1. My Target AI System

Human Resource Chatbot an example of this is an AI powered automated system to streamline and automate HR tasks, like answering FAQ's, Guiding the onboarding process.

2. Mapping, Analysing and Prioritising Possible Threats

MITRE ATLAS™

Matrix

Tactics

Techniques

Mitigations

Case Studies

Works in research or controlled settings, but is not necessarily demonstrated in realistic operations.

Contribute

Reconnaissance

8 techniques

Active Scanning

Gather RAG-Indexed Targets

Gather Victim Identity Information

Search Application Repositories

Search Open AI Vulnerability Analysis

Search Open Technical Databases

Search Open Websites/Domains

Search Victim-Owned Websites

Resource Development

13 techniques

Acquire Infrastructure

Acquire Public AI Artifacts

Develop Capabilities

Establish Accounts

LLM Prompt Crafting

Obtain Capabilities

Poison Training Data

Publish Hallucinated Entities

Publish Poisoned AI Agent Tool

Publish Poisoned Datasets

Publish

Initial Access

7 techniques

AI Supply Chain Compromise

Drive-by Compromise

Evade AI Model

Exploit Public-Facing Application

Phishing

Prompt Infiltration via Public-Facing Application

Valid Accounts

AI Model Access

4 techniques

AI Model Inference API Access

AI-Enabled Product or Service

Full AI Model Access

Physical Environment Access

Execution

6 techniques

AI Agent Clickbait

AI Agent Tool Invocation

Command and Scripting Interpreter

Deploy AI Agent

LLM Prompt Injection

User Execution

Persistence

9 techniques

AI Agent Context Poisoning

AI Agent Tool Data Poisoning

AI Agent Tool Poisoning

LLM Prompt Self-Replication

Manipulate AI Model

Modify AI Agent Configuration

Poison Training Data

Prompt Infiltration via Public-Facing Application

RAG Poisoning

Privilege Escalation

4 techniques

AI Agent Tool Invocation

Escape to Host

LLM Jailbreak

Valid Accounts

Defense Evasion

15 techniques

AI Supply Chain Reputation Inflation

AI Supply Chain Rug Pull

Corrupt AI Model

Delay Execution of LLM Instructions

Evade AI Model

Exploitation for Defense Evasion

False RAG Entry Injection

Impersonation

LLM Jailbreak

LLM Prompt Obfuscation

LLM Trusted Output Components Manipulation

Manipulate User LLM

Credential Access

6 techniques

AI Agent Tool Credential Harvesting

Credentials from AI Agent Configuration

Exploitation for Credential Access

OS Credential Dumping

RAG Credential Harvesting

Unsecured Credentials

Discovery

9 techniques

Cloud Service Discovery

Discover AI Agent Configuration

Discover AI Artifacts

Discover AI Model Family

Discover AI Model Ontology

Discover AI Model Outputs

Discover LLM Hallucinations

Discover LLM System Information

Process Discovery

Lateral Movement

2 techniques

Phishing

Use Alternate Material

Researching the MITRE ATLAS and the OWASP top 10, gives you a better understanding of how people might exploit ai systems.

Mapping Possible Threat Table

System Layer	Threat	Mitigations
Input Layer	Prompt Injection (malicious query override instructions)	Input filtering, regex and guardrails
LLM Processing Layer	Data Leakage (LLM Reveals Sensitive Data)	Safety classifications, restricted system prompts, limited context window
HR Document Database	Unauthorised DB access (retrieving payroll/SSN data)	Role based access control, encryption at rest
Output Layer (Chatbot Response)	Hallucinations (false or misleading answers)	Output filtering, human to human loop for sensitive queries
System Infrastructure	API Misuse (DoS, Insecure logging, weak authentication)	API rate limits, secure logging

3. Analysing The STRIDE Threat Modelling Methodology

Stride stands for, Spoofing, Tampering, Repudiation, Information Discloser, Denial Of Service and Elevation of Privilege.

How something like this could work in practice?

Model the system, creating a data flow diagram to map out how the data moves, Identify Threats, Apply the STRIDE Framework and brainstorm how attackers might exploit the system.

4. Proposed Mitigations In The Scenario Of An “AI Human Resource Chatbot”

My proposed mitigations include a multi layered approach to keeping an AI human resources chatbot safe. Sanitisation so filtering out unknown or specific language eg “ignore previous instructions” before they reach the LLM, also implementing guardrails deploying specific tools to block jailbreak attempts in real time. Ensuring the chatbot only access specific tools it needs avoid giving the chatbot unrestricted access to tokens and admin rights. Limit sessions by short lived and scoped API keys. All of these previous ideas can be combined with continuously monitoring and surveillance following on with security best practices.